

Firmware 7.15 · Block 5 audit report

Zcash Orchard viewing-key authorization and account identity · 22 September 2026

Local audit judgment: the frozen 7.15 full candidate retains unconditional viewing-key export consent and rejects aliased explicit account indices. The two direct host regressions and surrounding 21-case Zcash set passed on the pinned full emulator image. No new in-scope product defect was identified by source and test review.

1. Identity, scope and source

Block P05 was selected by inference from candidate history after no pre-existing P05 scope or branch was found. The owner accepted that selection method. Worktree `/private/tmp/kk-fw-715-p05-review`, branch `audit/715-p05-final-review`. Review base: `audit/715-p04-final-review @ 92931c91dc77bf2cdf80aaa8938b978add0cfde8`. Candidate source: `audit/715-scope-repair @ 614425a2a14d0113de251e7944118e47f31f5265`. Canonical product: `release/7.15 @ af979cd5099349ba58ec10d1b7eedeb67662c602`. The candidate and product are separate; no develop merge or release promotion occurs here. The main-worktree master template SHA-256 is `5503bc620856323eaa569dfb86016ae6275421a962c52b8e7eb1a65dc8ba63e4`, and the matching snapshot is in this branch.

Selected invariant: a host cannot suppress on-device consent for Orchard full viewing-key export; explicit account indices with bit 31 set are rejected rather than mapped to another account. The shared resolver also serves PCZT signing and Zcash address display. Cryptographic implementation, nonce generation, PCZT transaction review, and inherited storage durability are outside this unit. The full variant carries Zcash; Bitcoin-only omits these messages.

Candidate dependency pins

Dependency	Exact pin
code-signing-keys	a6470bd8598e5e9a7bfc38bf139a5e5a616f05ec
deps/crypto/trezor-firmware	8a392f70a5d5575ece3dfb35f115d4a4b27f497c
deps/device-protocol	27d3fa1f6215139cde6411f9a2882f36bb373fc9
deps/googletest	7888184f28509dba839e3683409443e0b5bb8948
deps/python-keepkey	b76ee610dd18934ee3aeeb36cfc541e8799eb46d
deps/qrenc/QR-Code-generator	6dfbfdad5d9303ed190d1c3cb7bec34b565b6ce8
deps/sca-hardening/SecAESSTM32	71d356a1141624994cf613bd2d2583892e8e6d5a

2. Git line inventory and behavior

Historical counts below are each commit's `git show --format= --numstat --no-renames COMMIT`, not a net candidate diff. The original unit changed a Python submodule pointer (+1/-1), one unit note (+16/-0), and the firmware handler (+9/-2). The later interaction commits touch nearby Zcash or workflow code; their counts are not added to the original unit as a net diff.

Commit and files	+ / -	Prior behavior → current behavior, significance and evidence
d4c82dd33fabe84c41151bf73eb322839dff9660 Python pointer; unit note; fsm_msg_zcash.h	1/1; 16/0; 9/2	The host could waive viewing-key confirmation and a high-bit explicit account aliased a lower account. The FVK handler now always requests consent, while the shared resolver rejects the high bit. The historical note records before/after host controls; the current pinned host tests pass.
1c67a2a60 fsm_msg_zcash.h	16/1	Later Orchard action validation requires every field used in the action commitment. It shares the handler file but does not remove the FVK consent or account check. Separate release scope.
7295f534c fsm_msg_zcash.h	10/9	Later transparent-input refusal prevents signing an input the device cannot sign. It does not change the selected FVK export path. Separate release scope.
c3ec59c35 workflow/FSM/test files and fsm_msg_zcash.h	125/5 across seven files; Zcash file 2/0	Later cross-workflow acknowledgement guard adds Zcash workflow state handling. Source review found no bypass of the resolver or FVK confirmation. Its own workflow tests remain separate.

Review-PR inventory

Reproduce the final inventory with `git diff --numstat`

92931c91dc77bf2cdf80aaa8938b978add0cfde8..REPORT_PREDECESSOR. The report and PDF are committed before replacing this predecessor token with an immutable SHA. Compare every row to the containing final head; the PR changes audit documents only, with no firmware source, test, workflow, or submodule pointer change.

Review-PR file	Added	Deleted	Purpose
docs/release/MASTER-AUDIT-TEMPLATE.md	33	0	Preserve main-worktree Block 00a status and record completed P02–P04 checkpoints, with P01/P05/P06 status.
docs/release/audit-units/P05-block-scope-20260922.md	101	0	Freeze inferred scope, pins, source reconciliation, tests and limits.
docs/release/audit-units/P05-audit-report-20260922.html	TBD	0	Readable final report source.
docs/release/audit-units/P05-audit-report-20260922.pdf	–	–	PDF rendered from the HTML source.

3. Current-source disposition

Finding	Disposition and exact evidence
---------	--------------------------------

FVK export without consent	Fixed in the candidate. lib/firmware/fsm_msg_zcash.h:959–1015 calls confirm regardless of show_display, returns ActionCancelled before key derivation on rejection, and only then builds a response. test_fvk_export_requires_consent_even_when_display_is_false drove the full handler and passed.
High-bit explicit account alias	Fixed in the candidate. zcash_resolve_account at fsm_msg_zcash.h:187–216 rejects bit 31 before returning an explicit account; callers are PCZT signing, FVK export, and address display. test_explicit_account_cannot_alias_across_harden_d_bit rejects both 0x80000000 and 0xffffffff through the FVK handler. The other two handlers share this source check but lack equivalent high-bit host regressions in the inspected companion tests.
Inherited erase-before-replacement power interruption	Pending outside this block. The release owner deferred its redesign to the separate storage program. This Zcash unit does not classify it as fixed or safe.

4. Verification and artifact identity

Check	Source/image or run	Result	Artifact and limit
Direct FVK regressions	Full image sha256:18f7375986270c6bd cea6155e9fe8382d5a4faca8 f0466ff3bf727b759a2e9f3	2 passed, 5 deselected	Direct handler policy-off and high-bit cases; no physical OLED observation.
Full Zcash host set	Same full image; PYTHONPATH=. python3 -m pytest -q --disable- warnings on four named Zcash files	21 passed	host-full.log SHA-256 f3c14ad15838f4c7165881da 5ceaf6ea1dba15fe3c8f5830 915d5dfa24443ea6
Bitcoin-only exclusion	Image sha256:12d356b3912a0e7f7 6923db50368ee66e979fed39 35174b6084726090a8f99db; same command	21 skipped; Zcash messages omitted	host-bitcoin-only.log SHA-256 69558acfa9f2db78c7e67520 2aa98bd28ed726637aaab47c ec2462a46ae59eb0. These are skips, not passes.
Full and Bitcoin-only native/ board	Same pinned P03 owned images and logs; make xunit	Full: 573 firmware, 17 board, 18 crypto, 6 Pallas. Bitcoin-only: 131 firmware, 17 board, 18 crypto.	Carried evidence because this PR's non-documentation diff against candidate source is empty; see P03/P04 receipts for log hashes.
ARM/SRAM and host CI	Earlier code/test/pin-equivalent run 34951131013 at 7e091af157131897adc5514d e392570c32088946	Full and Bitcoin-only ARM/ SRAM jobs passed; host and native artifacts passed.	Workflow files changed later; this is supporting evidence, not an exact-head workflow pass.

The four host files are test_msg_zcash_orchard.py, test_msg_zcash_seed_fingerprint.py, test_msg_zcash_sign_pczt_device.py, and test_msg_zcash_display_address.py. The current Python pin is b76ee610dd18934ee3aeeb36cfc541e8799eb46d. The two local images were built against that pinned candidate source and pins; this review branch changes only audit documents. The full host run reported 100 Python deprecation warnings, not failures. Physical FVK screen confirmation and signed-device upgrade remain release gates.

5. Render and local preflight

The PDF is generated from this HTML source with `weasyprint`. Before review: open first and last pages, verify table legibility, recheck live base/source/product heads, compare the immutable predecessor inventory above with the final head, run `git diff --check`, and update the PR body with the containing final SHA. No Copilot request is justified until these checks pass. This report does not claim product release acceptance.

6. Copilot checkpoint

Pending. The SOP allows one initial request after local preflight and at most one corrective request without a new owner decision. A current-head review with `Findings: None`, zero inline findings and zero unresolved threads is the checkpoint; physical-device and release promotion gates remain separate.